17.1 页面清单（MVP）

移动端 MVP 以企微/钉钉/飞书 H5 嵌入为起步形态，页面按优先级排布。

页面	功能	优先级	依赖
工作台首页	快捷入口、待办、搜索/语音提问、我的知识	P0	SSO、待办接口、知识检索
Agent 对话页	语音/文字提问、卡片化结果、引用来源、一句话触发工作流	P0	Agent 服务、RAG 召回（带权限）
审批页	入驻/共享/导出申请一键通过驳回、已处理记录	P0	审批流、权限校验
知识检索页	搜制度/产品/案例，带可见范围标识的结果	P1	RAG 召回、权限标识
我的知识页	个人/部门知识查看与轻量编辑	P1	知识库读写接口
用量看板（移动简版）	本部门用量、告警	P2	统计接口

17.2 接口 / 能力清单

接口 / 能力	说明	权限约束	优先级
SSO / OAuth 登录	对接企业 IM 网页授权，获取员工身份与部门	设备绑定、二次验证	P0
带权召回 / RAG 检索	与 PC 同一召回服务，注入调用者身份，返回授权片段	scope/owner/dept 过滤（不可绕过）	P0
Agent 触发	自然语言映射工作流，调用带权工具	调用者上下文随任务下发	P0
审批 API	查询待办、通过/驳回、记录操作人	仅平台管理员/授权人可审批	P0
知识读写（个人/部门）	新建/编辑/删除个人与部门知识	受 RBAC 与 scope 约束	P1
用量统计	部门/个人用量、成本分摊	部门看本部门、平台看全部	P2
审计日志	操作留痕、导出审批记录	平台管理员/授权人可见	P1

17.3 移动端权限点清单

权限点	说明	校验位置
登录身份	IM 网页授权获取 userId / deptId	SSO 网关
可访问部门空间	仅本人所属部门 + 授权共享部门	RBAC + 召回层
可见知识范围	全域公开 + 本部门 + 个人	召回过滤（同 PC）
审批资格	平台管理员 / 部门管理员 / 授权人	审批 API
敏感页操作	高敏部门可选禁截屏/禁复制	前端策略 + 后端校验
导出审批	敏感导出走审批流	审批 API + 审计

17.4 技术排期建议（MVP 4–6 周）

周次	任务	产出
W1	SSO 对接 IM、H5 框架搭建、登录与设备绑定	可登录 H5
W2	复用 PC 召回/RAG 与 Agent 服务，接入对话页	手机可问答、可触发 Agent
W3	工作台首页 + 搜索/语音 + 待办聚合	首页可用
W4	审批页（通过/驳回/记录）联调	移动审批闭环
W5	权限一致性联调、越权用例验证、安全（水印/禁截屏）	安全验收通过
W6	试点部门真实任务验收 + MVP 复盘	MVP 交付

17.5 验收标准

移动端 MVP 交付前必须通过的验收项：

- 手机端与 PC 端同一账号、同一可见范围（跨部门 / 越级不可见）
- 问答结果与引用来源一致，召回不绕过权限层
- 审批操作留痕、可回溯；敏感导出走审批
- 弱网下核心问答可用（预缓存命中）

17.6.1 带权召回 / RAG 检索（核心，不可绕过）

POST /api/v1/rag/retrieve —— 与 PC 同一召回服务，注入调用者身份后在召回阶段按 scope / owner / dept 过滤。

请求字段	类型	必填	说明
query	string	是	用户自然语言问题（经脱敏后入参）
kb_scope	enum	否	all / department / personal，默认 all（仍受身份约束）
top_k	int	否	返回片段数，默认 6，上限 20
tenant_id	string	是	企业租户隔离
caller*	object	是	网关注入 {userId,deptId,role}，前端不可伪造

响应示例：


```
{
  "code": 0,
  "data": {
    "query": "五一活动话术",
    "hits": [{
      "doc_id": "doc_8831",
      "title": "五一营销活动方案 v3",
      "snippet": "建议分三档：① 到店礼 ② 满减 ③ 老带新",
      "scope": "department",
      "kb_tier": "department",
      "score": 0.91,
      "source": "产品手册 v3",
      "can_access": true
    }],
    "filtered_out": 3,
    "trace_id": "trace_2026abc"
  }
}
```


注：caller 由网关从 Bearer Token 解析注入（X-Caller-Context 头），前端不传；filtered_out 仅返回越权片段计数，不返回内容。

17.6.2 SSO / OAuth 登录（对接企业 IM）

POST /api/v1/auth/sso/callback —— 接收企微/钉钉/飞书网页授权 code，换取员工身份与部门，并做设备绑定。

请求字段	类型	必填	说明
provider	enum	是	wecom / dingtalk / feishu
code	string	是	IM 回调授权码（一次性）
device_id	string	是	设备指纹，用于绑定与换机二次验证
state	string	否	防 CSRF

响应示例：

```
{
  "code": 0,
  "data": {
    "token": "",
    "expires_in": 7200,
    "user": { "userId": "u_1024", "name": "张三", "deptId": "d_sales", "role": "employee" },
    "device_bound": true,
    "need_stepup": false
  }
}
```

注：need_stepup 为 true 时（换设备）需二次验证后方可登录。

17.6.3 Agent 触发（自然语言映射工作流）

POST /api/v1/agent/invoke —— 调用者上下文（caller）随任务下发，Agent 调用的工具同样走带权召回。

请求字段	类型	必填	说明
agent_id	string	是	目标 Agent（如 sales_script）
input	string	是	用户输入（语音经 ASR 转写后传入）
stream	bool	否	是否 SSE 流式，默认 true
caller*	object	是	{userId,deptId,role}，工具调用继承此身份

响应示例：


```
{
  "code": 0,
  "data": {
    "answer": "建议分三档执行五一活动：到店礼、满减、老带新……",
    "citations": [ { "doc_id": "doc_8831", "title": "五一营销活动方案 v3", "scope": "department" } ],
    "tool_calls": [ { "tool": "rag_retrieve", "authorized": true } ]
  }
}
```

17.6.4 审批 API（入驻 / 共享 / 导出）

POST /api/v1/approval/{approval_id}/decide —— 仅平台管理员 / 部门管理员 / 授权人可审批，记录操作人。

请求字段	类型	必填	说明
decision	enum	是	approve / reject
comment	string	否	审批意见
operator*	object	是	网关注入审批人身份，校验其审批资格

响应示例：


```
{
  "code": 0,
  "data": {
    "approval_id": "ap_5502",
    "status": "approved",
    "decided_by": "u_admin_01",
    "decided_at": "2026-05-01T09:12:00Z",
    "audit_id": "audit_77"
  }
}
```

17.6.5 知识读写（个人 / 部门）

POST /api/v1/kb/documents —— 受 RBAC 与 scope 约束；写入时强制回填 owner_id / dept_id / scope 元数据。

请求字段	类型	必填	说明
title	string	是	文档标题
content	text	是	正文（入库自动向量化）
scope	enum	是	personal / department / global（global 仅平台管理员）
dept_id	string	条件	scope=department 时必填，强制等于 caller.deptId
caller*	object	是	网关注入，服务端校验写权限

响应示例：

```
{
  "code": 0,
  "data": {
    "doc_id": "doc_9001",
    "scope": "department",
    "owner_id": "u_1024",
    "dept_id": "d_sales",
    "indexed": true
  }
}
```

注：所有写接口的 scope / dept_id 以服务端 caller 为准，前端传入仅作展示，防止越权写库。

18.1 共用同一召回过滤层

PC 与移动端都调用**同一个 RAG 召回服务**：请求携带调用者身份（userId / deptId / role），服务在**召回阶段**即按 scope / owner / dept
过滤，越权片段根本不进入大模型上下文。两端没有任何“旁路”——手机端不是只读镜像，而是同一服务的不同前端。

- 同一过滤代码：过滤逻辑只在召回服务实现一次，PC/移动共用
- 同一元数据：每条知识带 (owner_id, dept_id, scope)，两端一致
- 同一 RBAC：角色与策略在服务端校验，前端仅做展示

18.2 一致性检查清单

检查项	PC 端	移动端	判定
可见部门空间	仅所属部门	仅所属部门	应一致
可见知识范围	全域+部门+个人	全域+部门+个人	应一致
越权访问测试	不可见对方部门	不可见对方部门	应一致
审批资格	按角色	按角色	应一致
审计留痕	全量记录	全量记录	应一致
导出审批	敏感走审批	敏感走审批	应一致

18.3 风险与纠偏

- 风险：移动端为赶进度“临时放宽”过滤，或前端缓存越权内容
- 纠偏：过滤器只在服务端，前端不持有越权数据；缓存仅存脱敏摘要
- 测试：两端共用同一套越权测试用例，CI 中强制回归
- 审计：两端操作统一进入同一审计流，出现差异可追溯到具体入口

18.4 数据流对照图：PC 与移动端共用召回过滤（单一过滤点）

下图强调：PC Web 与手机 H5/App
是**同一个召回服务的两个前端**，不存在“移动端只读镜像”或“旁路”。所有权限判定集中在**唯一过滤点**（scope / owner / dept），越权片段在召回阶段即被剔除，根本不进入大模型上下文。

